How Traceveil works

A practical guide from raw IoT input to events, findings, risk scores, alerts and incidents.

INPUT batch file or live sensor	ADMIT validate and save receipt	NORMALIZE Canonical Event v1.0	ANALYZE rules + correlation	PRESENT case views + report

Four terms to keep separate

Event	One accepted, normalized observation. Most events are ordinary readings.
Finding	A detection rule matched one or more events and recorded its conditions.
Alert	A finding whose trigger includes live evidence.
Incident	A bounded group of related findings and their supporting events.

1 Input and admission

Batch path: An investigator uploads a file with a source profile. Traceveil hashes the original bytes (SHA-256), validates file and row contracts, then commits only accepted rows. A duplicate file hash in the same case is recognized.

Live path: An ESP32/DHT22 reading arrives over USB, or a known source sends authenticated HTTP telemetry. Traceveil checks the source, active case session, size, rate and sequence. It writes a durable receipt before a worker processes the message.

Important: A receipt means input was queued, not that analysis finished. USB setup waits for the first reading to be fully saved before showing Capturing.

2 Canonical event

Accepted input is mapped to Canonical Event v1.0: event ID, case, event type, observed time, ingested time, entities, attributes and provenance (source hash, row/sequence reference, adapter and version). A USB sample becomes a telemetry event with temperature and humidity attributes. The laptop supplies its UTC receipt time in USB mode.

An event is a record of what arrived. It is not automatically suspicious.

Detection rules

The default rule set is deterministic: each finding records its supporting events, the condition tested, the actual value and the threshold.

Rule	Exact default trigger	Why it exists
LABEL-001	Source label matches configured malicious labels. TON_IoT: binary label = 1. CICIoT2023: label is not benign.	Clearly identifies a publisher-provided label; not independent attack discovery.
RATE-001	requests >= 3 x positive declared baseline	Flags an unusually high request count.
AUTH-001	At least 10 failed authentications within 60 s for the same device/target and actor.	Detects a repeated-failure pattern; powers the controlled alert demo.
BASELINE-001	After >= 3 earlier samples: current > mean(history) + max(1, 3 x population SD). Uses at most 20 prior samples.	Detects a high telemetry value relative to that device's own history.
TELEMETRY-ROC-001	After >= 3 prior changes: abs(current - previous) > max(1, 5 x median(prior absolute changes)).	Detects a rapid change even when the absolute value is not high.
NET-FANOUT-001	One source IP reaches >= 20 distinct destination IPs within 60 s.	Flags unusually broad destination activity.
NET-PORTSCAN-001	One source IP reaches >= 15 distinct destination-IP/port pairs within 60 s.	Flags destination/port probing patterns.
NET-FAILURE-001	One source IP has >= 20 failed or incomplete flows within 60 s.	Flags a burst of unsuccessful connections.

Rule scope matters: DHT22 temperature/humidity readings can contribute to telemetry rules. The demo's AUTH-001 events come from a separate, labelled software simulator; they are not attacks observed on the physical sensor.

What creates a live alert?

A rule first creates a finding. If a triggering event in that finding has live provenance, Traceveil creates an alert carrying the finding's severity and risk score. A batch-only finding does not become a live alert.

Defaults shown here come from analysis/config.py and analysis/detection.py. Thresholds can be changed in configuration; a rule's fixed confidence is not a measured accuracy percentage.

How risk is calculated

Risk is calculated per finding. It is a 0-100 triage score, not a probability that an attack occurred.

Base risk = 0.30 x severity + 0.25 x rule confidence + 0.20 x repetition + 0.15 x device criticality + 0.10 x corroboration

Factor definitions

Severity	Low 25; medium 50; high 75; critical 100.
Confidence	Fixed by the rule version; AUTH-001 uses 98. Not statistical accuracy.
Repetition	min(100, round-half-up(occurrences x 100 / rule reference count)).
Criticality	Configured per device, otherwise 50.
Corroboration	100 for an external correlation link; 75 for internal supporting links; 50 for multiple evidence objects without a link; otherwise 0.

After round-half-up of the weighted total, applicable penalties are subtracted, with a floor of zero. Examples: -5 for unknown identity, -5 for missing observed time, -10 for an unrecognized generic source label, and -5 for a limited rate-of-change baseline.

Worked example - AUTH-001: severity 100, rule confidence 98, repetition 100, default criticality 50 and internal corroboration 75 give
30 + 24.5 + 20 + 7.5 + 7.5 = 89.5, rounded to 90/100 (assuming no penalty).

Risk bands

Low: 0-24 Medium: 25-49 High: 50-74 Critical: 75-100. A finding's severity label and its final risk band may differ.

Corroboration comes from correlation edges

Two events are linked only when their observed times are within 120 seconds and they share a device, actor, target, network address or service. Time proximity alone is not enough.

The final score and every contributing factor are stored with the finding, so the number can be inspected later.

From findings to the final case

Traceveil groups and presents the saved results; the browser and optional AI do not recalculate forensic conclusions.

Incidents

Traceveil connects events that support findings and adds qualifying correlation links. Connected groups are split when the gap between finding triggers exceeds 120 seconds, the group's trigger span exceeds 120 seconds, or it would exceed 4,096 events. The incident's risk is the maximum finding risk; its severity is the highest finding severity.

Timeline and saved analysis

The analysis stores findings, live alerts, incidents, timeline entries, device relationships, charts and activity windows in SQLite. The timeline includes ordinary events as well as findings and alerts, sorted by observed time when available. Saved analysis can be reopened after capture stops.

Live dashboard and final report

The backend sends server-sent event (SSE) notifications to the dashboard. On a disconnect, the browser resumes from its last event ID or refetches authoritative case data if replay is unavailable. Reports are assembled from persisted results. Optional local AI can explain saved records but does not decide rules or scores.

Demo sequence: real DHT22 reading -> saved telemetry event -> live display. Then Simulate alert queues labelled authentication failures under traceveil-simulator -> AUTH-001 finding -> live alert -> incident and timeline. The physical sensor was not compromised.

Where to verify this in the project

Input: backend/app/services/batch.py; backend/app/services/usb_sensor.py; backend/app/services/phase3.py

Canonical event: backend/app/normalization/schemas.py; backend/app/normalization/adapters.py

Rules and scoring: backend/app/analysis/config.py; detection.py; correlation.py; risk.py; service.py

Timeline and delivery: backend/app/analysis/timeline.py; backend/app/api/phase3.py; docs/phase3-live-demo.md

This guide describes the repository's implemented default behavior. It does not claim measured detection accuracy, independent sensor calibration or production forensic certification.